TEMPLATE REPORT

REVERSE BINARY

TEMPLATE REPORT

Table of Contents

Black-box Audit

In this phase, we analyzed the binary using reverse engineering tools and manual

fuzzing. List of the tools you used:

- Ghidra
- UPX

Key discoveries:
- Hardcoded values & secrets
- Overflows
- Weak encryptions
- Insecure Global Variables
- Insecure Deserialization
- Insecure Randomness
- Unverified Casting Types
- NULL Pointer Dereference
- Log Injection
- Use after free()

White-box Audit

With access to source code, we performed a full code review and vulnerability assessment.

Focus areas:

- Input validation
- Memory safety (heap/stack misuse)
- Format string handling
- Privilege escalation paths

Additional vulnerabilities discovered:
- Hashing sensitive values
- Asking for credentials when sensitive data is about to get leaked

List of the tools you used:
- Ghidra (for the .so file)
- Git

Vulnerability Report

Below is the list of vulnerabilities discovered:

Vulnerability #1: activate_emergency_protocols

Severity: Critical
Type: Hardcoded Credentials
Location: src/activate_emergency_protocols.c,
Function : activate_emergency_protocols
Discovered in: Black-box

Description:
The password is hardcoded.

Proof of Concept:
You can find it in Ghidra.

Impact:
Privilege Escalation

Fix Summary:
  Use of macro in the header file.
  Patch file: activate_emergency_protocols.patch

Unit Test: No
Test Coverage: None

Vulnerability #2: check_cooling_pressure

Severity: Medium
Type: Use after free
Location: src/check_cooling_pressure.c,
Function : check_cooling_pressure
Discovered in: White-Box

Description:
A variable is used after a free.

Proof of Concept:
free inside the function.

Impact:
Memory Leak.

Fix Summary:
  Move the free after the last usage of the variable.
  Patch file: check_cooling_pressure.patch

Unit Test: No
Test Coverage: None

Vulnerability #3: check_reactor_status

Severity: High
Type: Weak Encrypting
Location: src/check_reactor_status.c,
Function : check_reactor_status
Discovered in: White-Box

Description:
The chosen encryption (Cesar) is too weak .

Proof of Concept:
The encrypt function inside the file.

Impact:
Data Leak

Fix Summary:
- Change encryption for Hash.
- Patch file:check_reactor_status.patch

Unit Test: No
Test Coverage: None

Vulnerability #4: configure_cooling_system

Severity: Critical
Type: Insecure Deserialization
Location: src/configure_cooling_system.c,
Function : configure_cooling_system
Discovered in: Black-box

Description:
The user can add some bad command to a configuration file from your computer, that will be executed.

Proof of Concept:
You need to put a command in the config_cooling.txt file.

Impact:
Reverse Shell.

Fix Summary:
- Check du buffer lu par la commande.
- Patch file: configure_cooling_system.patch

Unit Test: No

Test Coverage: None

Vulnerability #5: load_fuel_rods

Severity: High
Type: Buffer Overflow
Location: src/load_fuel_rods.c,
Function : load_fuel_rods
Discovered in: Black-box

Description:
Put an input longer than 10 to make the array overflow.

Proof of Concept:
Insert a more than 10 length input.

Impact:
Data Leak.

Fix Summary:
Read until the size of the input variable.
Patch file: load_fuel_rods.patch

Unit Test: No
Test Coverage: None

Vulnerability #6: monitor_radiation_levels

Severity: High
Type: Stack-Based Buffer Overflow
Location: src/monitor_radiation_levels.c,
Function : monitor_radiation_levels
Discovered in: White-box

Description:
Overflowing the buffer to write data somewhere that is not supposed to be.

Proof of Concept:
Writing "AAAAAAAAAA\xb6\x84\x04\x08" as input to write data inside “function_ptr” variable.

Impact:
Code injection.

Fix Summary:
Read until the size of the input variable.
Patch file: monitor_radiation_levels.patch

Unit Test: No
Test Coverage: None

Vulnerability #7: run_diagnostic

Severity: High
Type: NULL Pointer Dereference
Location: src/run_diagnostic.c,
Function : run_diagnostic
Discovered in: White-box

Description:
A null-pointer dereference takes place when a pointer with a value of NULL is used as though it pointed to a valid memory area.

Proof of Concept:
Writing "debug” as input for diagnostic mode.

Impact:
Unpredictable behaviour or Crash.

Fix Summary:
Check if the pointers are null.
Patch file: run_diagnostic.patch

Unit Test: No
Test Coverage: None

Vulnerability #8: send_status_report

Severity: High
Type: Weak encrypting
Location: src/send_status_report.c,
Function : send_status_report
Discovered in: Black-box

Description:
Status is encoded with base64.

Proof of Concept:
Read the file Data/status_report.txt after this function’s call.

Impact:
Data Leak.

Fix Summary:

Change encryption for Hash.
Patch file: send_status_report.patch

Unit Test: No

Test Coverage: None

Vulnerability #9: set_reactor_power

Severity: High

Type: Integer Overflow

Location: src/set_reactor_power.c,

Function : set_reactor_power

Discovered in: Black-box

Description:

A number larger than the limit of its type size, resulting in.

Proof of Concept:

If you put 2147483646 as input, it will overflow.

Impact:

Unpredictable behaviour or Crash.

Fix Summary:

Use a long int variable to check if input is higher than the int limit.
Patch file: set_reactor_power.patch

Unit Test: No

Test Coverage: None

Vulnerability #10: simulate_meltdown

Severity: Medium

Type: Insecure Randomness

Location: src/simulate_meltdown.c,

Function : simulate_meltdown

Discovered in: Black-box

Description:

Function can produce predictable values that can cause errors.

Proof of Concept:

Function randomly meltdown.

Impact:

Can be exploited to gain advantage.

Fix Summary:

Make conditions more global.
Patch file: simulate_meltdown.patch

Unit Test: No

Test Coverage: None

Vulnerability #11: trigger_emergency_shutdown

Severity: Medium

Type: Exploit global variable

Location: src/trigger_emergency_shutdown.c,

Function : trigger_emergency_shutdown

Discovered in: White-blox

Description:

Global variable not used properly.

Proof of Concept:

The function used IS_ADMIN to trigger an emergency shutdown if false.

Impact:

Non-admin users could trigger an emergency shutdown.

Fix Summary:

Set the condition to trigger an emergency shutdown if IS_ADMIN is true.

Patch file: trigger_emergency_shutdown.patch

Unit Test: No

Test Coverage: None

Vulnerability #12: unlock_secret_mode

Severity: High

Type: Exploit global variable

Location: src/unlock_secret_mode.c,

Function : unlock_secret_mode

Discovered in: White-box

Description:

Global variable not used properly.

Proof of Concept:

The function used IS_ADMIN to unlock the secret mode if false.

Impact:

Code injection.

Fix Summary:

Set the condition to unlock the secret mode if IS_ADMIN is true.

Patch file: unlock_secret_mode.patch

Unit Test: No

Test Coverage: None

Vulnerability #13: load_config

Severity: High

Type: ROP Stack Overflow

Location: src/load_config.c,

Function : load_config

Discovered in: White-box

Description:

Stack overflow errors occur when a function writes more data in a buffer than it can contain, allowing it to overwrite the return address and control the execution flow.

Proof of Concept:

Using ROP : “ROPgadget --binary pipeto | grep ": pop rdi ; ret$" python2 -c "print('A' * offset + '\xXX\xXX\xXX\xXX\xXX\xXX\xXX\xXX' + '\xYY\xYY\xYY\xYY\xYY\xYY\xYY\xYY' + '\xZZ\xZZ\xZZ\xZZ\xZZ\xZZ\xZZ\xZZ')" > config.ini”

Impact:

Code injection.

Fix Summary:

Read until the size of the input variable.

Patch file: load_config.patch

Unit Test: No

Test Coverage: None

Conclusion

- ✓ Total vulnerabilities found: 16
- ✓ All were successfully patched.
- ✓ Final code is secure, maintainable, and ready for deployment.

Vulnerability Name	Patch File	Unit Tested	Coverage
activate_emergency_protocols	activate_emergency_protocols.patch - -	No	0%
check_cooling_pressure	check_cooling_pressure.patch -	No	0%
check_reactor_status	check_reactor_status.patch	No	0%
configure_cooling_system	configure_cooling_system.patch	No	0%
load_fuel_rods	load_fuel_rods.patch	No	0%
monitor_radiation_levels	monitor_radiation_levels.patch	No	0%
run_diagnostic	run_diagnostic.patch	No	0%
send_status_report	send_status_report.patch	No	0%
set_reactor_power	set_reactor_power.patch	No	0%
simulate_meltdown	simulate_meltdown.patch	No	0%
trigger_emergency_shutdown	trigger_emergency_shutdown.patch	No	0%
unlock_secret_mode	unlock_secret_mode.patch	No	0%
load_config	load_config.patch	No	0%

{EPITECH}